

IT-Forensik (VFH-Studiengang IT-Sicherheit)

Prof. Dr. Ulrich Baum, Technische Hochschule Brandenburg

Version 24.09

Laborversuch: Airport

Bewertung: Maximal 15 Punkte.

Einführung und Vorbereitung

In diesem Versuch untersuchen Sie einen Sicherheitsvorfall in der IT eines Flughafens anhand von Netzwerkmitschnitten und Logdateien.

Lesen Sie zunächst die **Seiten 6-12** des Dokuments `enisa-training-airport.pdf`. Sie enthalten eine Einführung in den Fall und wichtige Hintergrundinformationen dazu. Die dort genannten Tasks können Sie ignorieren; stattdessen werden Sie modifizierte Aufgaben bearbeiten, siehe unten. Das im Dokument verlinkte VM-Image brauchen Sie nicht!

Die Bearbeitung erfolgt in Parrot OS, die benötigten Tools sind dort bereits installiert.

Die zu analysierenden Daten finden Sie im Archiv `airport-files.tar.gz` (im Moodle-Verzeichnis). Laden Sie es in Ihrer Parrot-VM herunter und entpacken Sie es.

Bearbeiten Sie die folgenden Aufgaben und erstellen Sie einen Bericht dazu. Gliedern Sie Ihren Bericht nach den Aufgaben. **Geben Sie den vollständigen Bericht als PDF-Datei in Moodle ab.**

Aufgaben

Teil A: Analyse des Vorfalls

Dokumentieren Sie in Ihrem Bericht zu jeder Teil-Aufgabe:

- Die durchgeführten Analyseschritte nachvollziehbar in einer stichpunktartigen textuellen Beschreibung (bitte keine Klickanleitung / Screenshots!).
- Ihre Ergebnisse. Achten Sie auf eine klare Unterscheidung zwischen nachgewiesenen Fakten und Ihrer Interpretation.

-
1. Prüfen Sie die Integrität der zu untersuchenden Dateien, indem Sie deren Hashwerte mit denen im *Chain of Custody*-Formular vergleichen. Interpretieren Sie das Ergebnis.
 2. Finden Sie mit Kommandozeilen-Tools heraus, wie viele Login-Versuche des Users `admin` im Webserver-Log `access.log` protokolliert sind.
 3. Ermitteln Sie in `openvpn.log` die direkte IP-Adresse von Bobs Computer sowie die dafür im VPN vergebene IP-Adresse.

4. Wann wurde die vom Angreifer ausgenutzte VPN-Verbindung von Bobs Rechner aus gestartet und wie lange bestand sie? Werten Sie dazu zuerst `openvpn.log` und dann einen Netzwerkmitschnitt aus. Sind die Ergebnisse konsistent?
5. Welche zwei IP-Adressen haben den meisten IP-Traffic mit Bobs Computer? Welche davon ist wahrscheinlich die IP-Adresse des Angreifers? Warum?
6. Ermitteln Sie anhand des Netzwerkmitschnitts `routeritsaeu_20180726_enp0s8.pcap`, in welchen Schritten der Angreifer die Kontrolle über Bobs Rechner übernommen hat. *Dieser Punkt erfordert eine ausführliche Analyse und Antwort.*
7. Welche bekannte Verwundbarkeit hat der Angreifer wahrscheinlich ausgenutzt, um in Bobs Rechner einzubrechen? Tipp: Der Netzwerkmitschnitt enthält konkrete Hinweise, mit denen Sie das über eine Internet-Recherche herausfinden können.
8. Betrachten Sie den VPN-Verkehr zwischen Bobs Rechner und dem VPN-Server. Was können Sie über die Inhalte der Übertragung sagen? In welchem Zeitraum wurden größere Datenmengen aus dem VPN zu Bobs Rechner übertragen? Sind diese Daten weiter zum Angreifer geflossen?
9. Erstellen Sie eine detaillierte Zeitlinie des Vorfalls, beginnend mit dem Aufbau der VPN-Verbindung.
10. Ordnen Sie die untersuchten Datenarten und die verwendeten grundlegenden Methoden nach dem BSI-Leitfaden "IT-Forensik" ein.

Teil B: Schaden, Ursachen und Gegenmaßnahmen

Beantworten Sie in Ihrem Bericht folgende Fragen:

1. Welchen konkreten Schaden hat der Angreifer *nachweisbar* verursacht?
2. Welche wichtigen Fragen zu diesem Vorfall sollten durch weitere forensische Untersuchungen geklärt werden, für die die Ihnen vorliegenden Daten nicht ausreichen?
3. Wie haben Bob und sein Unternehmen dazu beigetragen, dass dieser Angriff möglich war?
4. Welche Maßnahmen empfehlen Sie Bobs Firma ITSAEU, um derartige Angriffe in Zukunft unwahrscheinlicher zu machen?
5. Der Flughafen möchte auf den Fernzugriff von Fremdfirmen über VPN nicht verzichten. Welche Sicherheitsmaßnahmen könnte die IT-Abteilung des Flughafens trotzdem gegen solche Angriffe treffen?